



University of Bahrain
College of Information Technology
Department of Information Systems
ITCY460 - Security Risk Assessment and Countermeasures

Group Project: Risk Mitigation Plan

Meridian FinTech Solutions

Second Semester 2025/2026

Aljazi Ali Almujaaddam - 202202227
Dana Hussain Alhayki - 202204341
Noora Abdulrahman Bumjaid - 202203245
Nada Abdulaziz Yahya - 202203864
Maram Abdulqawi Ghaleb - 202305067

Table of Contents:

Table of Contents:	2
1. Introduction	3
2. Scope and Boundaries	3
3. Additional Risks Identified	4
4. Risk-to-Mitigation Mapping	4
5. Control Categories	4
1. Administrative Controls	4
2. Technical Controls	5
3. Physical Security	5
7. Implementation Plan	6
8. Monitoring and Continuous Improvement	7
9. Cost-Benefit Analysis (CBA)	8
10. Conclusion	8
11. Appendices	9

1. Introduction

Meridian FinTech Solutions is a rapidly growing firm operating through cloud computing that offers various fintech products, including financial management, transaction processing, payment processing, fraud detection, and financial reporting. The company is a fully cloud-computed enterprise running through cloud providers such as AWS and Google Cloud and serving thousands of customers across the globe. In light of rapid growth, cloud computing, and the nature of operations, Meridian FinTech Solutions is faced with several cybersecurity risks, including those from cloud configuration errors, third-party integration, insider access, and social engineering. This report attempts to analyze and identify some of the risks to which Meridian FinTech Solutions is exposed as per the above scenario. The objective of this report is to develop appropriate strategies for mitigating the risks identified. For an effective identification and assessment process, some of the popular frameworks, including NIST SP 800-30, will be used.

2. Scope and Boundaries

In order to understand the security risks in Meridian FinTech Solutions, this report will focus on all the main cybersecurity risks that might threaten the company, especially since the firm operates using cloud computing platforms such as AWS and Google Cloud and deals with sensitive financial information.

Some of the main categories of risk identified in the report include cloud computing risk, employees' access risk, third-party risk, and data security risk. The other risks that the company needs to address to ensure its security include insider risk, unauthorized use of API keys, BEC phishing, and BYOD/Shadow IT risk. It should be noted that this report will cover the security risks facing the company and suggest some ways of mitigating the risks without going into technicalities such as code, designs, and configurations. There will also be a discussion of some physical security concerns, such as office access and device security.

3. Additional Risks Identified

In addition to those discussed in the initial threat assessment, a more thorough examination has revealed additional threats that can negatively affect Meridian FinTech Solutions:

1. Third Party Risk: Any reliance by Meridian FinTech Solutions upon its retail clients and/or banking partners creates an opportunity for exposure via exploitation of any vulnerabilities in third-party systems.

2. Data Privacy/Regulatory Risk: The fact that Meridian FinTech Solutions will be handling sensitive client financial information across various international jurisdictions creates an increased likelihood of failure to comply with applicable laws and regulations; i.e., General Data Protection Regulation

3. Insider Threat Privilege Misuse: Privileges afforded to employees having elevated access (i.e., DevOps Engineers) may be exploited either intentionally or inadvertently.

4. Risk-to-Mitigation Mapping

A detailed Risk-to-Mitigation Mapping Table, Appendix A, has been developed, which will identify each of the risks identified and provide details regarding the appropriate Mitigation Strategies, Control Categories, and Implementation Timelines for each risk identified. This table identifies how each risk identified has an associated Mitigation Strategy and provides details regarding the Implementation Schedules for each. The purpose of the Risk-to-Mitigation Mapping Table is to identify all risks identified and develop a plan to mitigate those risks.

5. Control Categories

1. Administrative Controls

Employees are guided by administrative control methods that promote safe employee behavior through policies, processes, and training. The implementation of these administrative controls include: A BYOD Policy (that requires encryption, automatic operating system upgrades, mobile device management) Secure coding practices, utilizing an automated process that scans secrets to help identify hard coded API keys

Phishing awareness training with simulated phishing attacks (in particular to employees at our Tokyo Office since they have been receiving a higher number of Business Email Compromise (BEC) attempts) Improved termination processes to ensure quick revocation of user rights. Administrative controls will assist in reducing potential risks associated with: Insider Threats, BYOD Vulnerabilities, Shadow IT, and Social Engineering Attacks.

2. Technical Controls

Technical Controls utilize technology to protect Meridian's Cloud Infrastructure & Applications. Examples of implementation include installing a central SIEM system to monitor both AWS & GCP, utilizing Least Privileged Access for IAM roles that are checked against CIS Compliance Benchmarks, implementing Multi-Factor Authentication on ALL Critical Systems, installing AWS Shield (DDoS Protection), installing an Endpoint Detection & Response System, & Encrypting Regular Backups of Sensitive Data. All these technical controls will address risks that include misconfigured Cloud Services, Lack of Centralized Monitoring, External Threats & Insider Misuse of API Keys.

3. Physical Security

Measures provide protection for Meridian's facilities, equipment, and assets by preventing unauthorized access to and theft of Meridian's facilities, equipment, and other assets. Some examples include use of a badge/biometric access system at each location; video monitoring systems that incorporate visitor check-in systems to monitor who is entering the facility; secure storage with inventory tracking systems for both company-issued devices and employee-bringed devices. Environmental controls, including but not limited to fire suppression systems and/or generators/back-up electrical sources, are also used to ensure that in the event of an emergency, there will be no loss of electrical services, which would allow employees to safely exit the facility. The implementation of these types of security measures can greatly reduce the likelihood of threats resulting from physical security vulnerabilities and/or equipment theft, as well as unauthorized access to sensitive information that may occur in open concept workspaces.

6. Prioritization of Risks

Meridian FinTech Solutions' risk management approach is a likelihood/impact model where the company assesses the relative likelihood and/or potential impacts of identified risks. Based upon the qualitative rating (Low, Medium, High) in the Risk Assessment Plan, the identified risks will be categorized as a Critical, High, Moderate, or Low priority. This allows Meridian FinTech to direct its limited resources toward mitigating the highest-priority risks first. A summary of all of the results from the above process is provided within the Risk Prioritization Table, which is contained in the Appendix.

7. Implementation Plan

Risk management at Meridian FinTech will begin with a phased approach to ensure that high-priority risks are managed while allowing operations to continue uninterrupted. Senior management, IT security, compliance, HR, and other departments will have responsibilities in risk management.

Weeks 1-13:

The focus will be on urgent high-priority risks, including insider threats, email compromise, shadow IT, and physical security. Rotating API keys, Improvement of email security, and enforcing communication policies through employee training; Employee awareness training, and upgrading access controls to improve physical security.

Months 14-26:

Device and cloud security improvements by introducing mobile device management (MDM), improving MDM functionality. Encryption and patch compliance for all devices. Access control enhancements for cloud services. Implementation of a centralized system for information and event monitoring (SIEM) to monitor activity across multiple platforms.

Month 27-52:

Provide ongoing employee education/training to strengthen the resilience of systems. Protection from

external attacks, including denial-of-service (DDoS) and ransomware. Expansion of endpoint protection to include additional devices. Penetration testing on an annual basis to identify vulnerabilities in existing systems.

Ongoing improvement

Annual reviews of current risks using frameworks such as NIST SP 800-30 and ISO 27001.

8. Monitoring and Continuous Improvement

The organization continually evaluates and improves the design of its Risk Mitigation Controls by continuously assessing and improving them through a continuing cycle as defined in NIST SP 800-30 and ISO 27001.

Real-Time Monitoring Activities: The organization monitors in real time for anomalies using AWS/GCP SIEM logs, continuously monitors endpoints and networks using IDS/IPS and EDR Tools, tracks all VPN and Remote Access activity, and continuously monitors Physical Security (surveillance, logs, visitor records).

Monthly Log Review and Quarterly Penetration Testing: Each month, the organization's Security Teams perform log review activities to investigate anomalies; each quarter performs penetration testing to evaluate the organization's defenses; and annually conducts qualitative risk assessments. The effectiveness of controls will be evaluated based on best practices established by NIST and ISO standards.

Ongoing Policy Reviews and Training, Lessons Learned and Gap Analysis: Continuously reviews policies (e.g., BYOD, Acceptable Use), provides employees with Ongoing Phishing Simulations and Training, incorporates lessons learned from past events into new strategic initiatives; and continuously analyzes compliance gaps to identify areas where improvements need to be made to existing control designs.

9. Cost-Benefit Analysis (CBA)

The economic feasibility of the chosen measures aimed at mitigating the identified cybersecurity risks in Meridian FinTech Solutions was examined through conducting a cost-benefit analysis (CBA). CBA estimates the financial losses due to the risks considered before and after the application of the suggested security measures to check whether the decrease in potential losses is worth the expenses necessary for implementation. To estimate the benefits of each proposed measure, it was necessary to calculate the difference between the losses expected before and after the introduction of the respective control. The next step included calculating the value of the countermeasure that consists of subtracting the expenses related to its implementation from the previously obtained benefits. As a result, it may be said that the chosen countermeasures have proved financially valuable for the organization under analysis. Detailed calculations and numerical results are provided in the Appendix.

10. Conclusion

This risk mitigation plan provides specific ways in which Meridian FinTech Solutions can mitigate various cybersecurity risks affecting the organization and the cloud environment of its financial services applications. Implementation of control measures will help minimize risks such as those of misconfiguration of cloud services, insider threats, phishing attacks, exposure of API keys, and poor protection of devices used for access. Implementation of control measures like continuous SIEM, improvements in IAM role management and MFA implementation, BYOD policies and practices, as well as increased employee awareness about cybersecurity matters, is expected to lower the risks of security incidents. Such mitigation measures will also help Meridian FinTech Solutions comply with standards such as NIST SP 800-30 and ISO 27001.

11. Appendices

Appendix A: Table 1: Risk-to-Mitigation Mapping

Below is a Risk-to-Mitigation Mapping Table which addresses how each identified Threat/Vulnerability is mitigated using appropriate Mitigation Strategies and Control Categories. The table details Administrative, Technical, and Physical Controls to be implemented and includes Implementation Notes detailing what action(s) need to be taken and by when. This structured approach will enable a methodical approach to implementing mitigation measures in accordance with the relative Risk Severity rating of the identified risks, and support enhanced Security Posture and compliance with industry standards, i.e., NIST SP 800-30 and ISO 27001.”

Threat / Vulnerability	Risk Rating	Mitigation Strategy	Control Category	Implementation Notes
Hard-coded API key (insider threat)	Critical	Rotate/revoke API keys, enforce secure coding standards, automate secret scanning, strict termination procedures	Administrative / Technical	Immediate action: IT Security to rotate keys and audit source code within 1 month
Business Email Compromise (Tokyo)	High	Deploy advanced email filtering, enforce DMARC/SPF/DKIM, conduct phishing awareness training, and implement financial approval workflows	Administrative	Short-term: Training rolled out in Tokyo office; Technical email controls deployed within 3 months

BYOD unpatched devices	High	Enforce BYOD policy, deploy Mobile Device Management (MDM), mandatory patching, and endpoint encryption	Administrative / Technical	Mid-term: MDM rollout across all employee devices within 6 months
Cloud misconfigurations (IAM roles, buckets)	Moderate	IAM role reviews, automated compliance checks, least-privilege enforcement, CIS benchmark alignment	Technical	Mid-term: Automated compliance tools deployed within 6 months
Lack of centralized SIEM	Moderate	Deploy a centralized SIEM solution, integrate AWS/GCP logs, and enable real-time monitoring	Technical	Mid-term: SIEM deployment planned within 6 months
Shadow IT communications	Moderate	Enforce approved collaboration tools, awareness campaigns, and monitor unauthorized apps	Administrative	Short-term: HR to update policies and enforce official tools within 3 months
Human factors (phishing/social engineering)	High	Security awareness training, simulated phishing campaigns, and stronger MFA enforcement	Administrative	Ongoing: Quarterly training and simulated phishing exercises
External attacks (DDoS, ransomware)	High	DDoS protection (AWS Shield), endpoint detection and response (EDR), regular backups, IDS/IPS	Technical	Immediate: AWS Shield enabled; Long-term: EDR rollout across all systems

Physical security weaknesses	High	Office access control systems, surveillance cameras, visitor management, and secure device storage	Physical	Short-term: Access control upgrades in Tokyo office within 3 months
------------------------------	------	--	----------	---

Appendix B: Table 2: Qualitative Risk Prioritization Matrix (Likelihood × Impact)

The risks listed in the table have been assigned using an impact/likelihood rating system as used by Meridian. This is a qualitative risk ranking system that ranks risks from low to high. These qualitative risk rankings are then converted into specific resource allocation priorities: Critical, High, Moderate, and Low.

Threat / Vulnerability	Likelihood	Impact	Risk Rating	Priority Level
Hard-coded API key (insider threat)	High	High	Critical	Immediate
Business Email Compromise (Tokyo)	High	Medium	High	Immediate
BYOD unpatched devices	Medium	High	High	Immediate
External attacks (DDoS, ransomware)	Medium	High	High	Immediate
Human factors (phishing/social engineering)	High	Medium	High	Immediate
Physical security weaknesses	Medium	High	High	Immediate
Cloud misconfigurations (IAM roles, buckets)	Medium	Medium	Moderate	Mid-Term
Shadow IT communications	Medium	Medium	Moderate	Mid-Term
Lack of centralized SIEM	Low	High	Moderate	Mid-Term

Appendix C: Table 3: Cost-Benefit Analysis of Selected Security Countermeasures

This cost-benefit analysis is aimed at evaluating the potential economic impact of the risky assets recognized by Meridian FinTech Solutions as well as whether the suggested strategies will provide any security benefits in light of the cost involved.

Risk	Countermeasure	Loss Before	Loss After	Projected Benefit	Cost	Countermeasure Value
Cloud misconfiguration	SIEM implementation	\$200,000	\$70,000	\$130,000	\$50,000	\$80,000
API key misuse/insider threat	IAM enforcement+ secret scanning	\$150,000	\$40,000	\$110,000	\$30,000	\$80,000
Phishing/BEC attacks	Awareness training program	\$120,000	\$30,000	\$90,000	\$20,000	\$70,000
BYOD device exposure	MDM solution	\$100,000	\$35,000	\$65,000	\$25,000	\$40,000

The projected benefits were calculated using the following formula:

Projected Benefit = Loss before countermeasure – Loss after countermeasure

For example:

Cloud misconfiguration risk:

$$\begin{array}{rcl} \text{Projected Benefit} & \text{---} & \text{Countermeasure Value} \\ = 200,000 - 70,000 & \text{---} & = 130,000 - 50,000 \\ = 130,000 & \text{---} & = 80,000 \end{array}$$

Since the value is positive, the countermeasure provides financial benefit and should be implemented.